

Informe Norma ISO 42001.

La Norma ISO/IEC 42001 no trae “la tabla mágica de KPIs de ciberseguridad para IA”, pero sí obliga a diseñarla, justificarla y medirla con la misma disciplina con la que un actuario mira una hoja de cálculo y un CISO mira un SIEM. A partir de ahí, se puede construir un sistema nacional de indicadores para España alineado con el Esquema Nacional de Seguridad, la ENIA, el EU AI Act y la estadística (cada vez más preocupante) de incidentes que reporta INCIBE.12345678

1. Qué exige realmente ISO 42001 sobre indicadores

ISO/IEC 42001 es un sistema de gestión para IA (AIMS) que sigue el ciclo PDCA y replica la lógica de ISO 27001: no te da métricas cerradas, te exige demostrar que sabes qué medir, cómo, cuándo y para qué. La “fábrica de indicadores” está sobre todo en la cláusula 9 (evaluación del desempeño) y en el Anexo A, que aterriza en controles concretos lo que antes eran buenas intenciones de gobernanza.910111213

La cláusula 9.1 obliga a definir qué se monitoriza, los métodos de medición, la frecuencia y cómo se analizan y evalúan los resultados, distinguiendo entre desempeño (resultados medibles) y eficacia (grado en que se logran los resultados previstos). Esto se complementa con auditorías internas del AIMS y revisiones por la alta dirección que deben basarse en evidencias cuantificables: tendencias de incidentes, eficacia de controles, cumplimiento de objetivos y ajustes necesarios.14151617

1 https://ai-watch.ec.europa.eu/countries/spain/spain-ai-strategy-report_en

2 https://portal.mineco.gob.es/RecursosArticulo/mineco/ministerio/ficheros/210204_Digital_Spain_2025.pdf

3 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

4 <https://www.iso.org/obp/ui/en/>

5 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

6 <https://eiposgrados.com/eng/cybersecurity-blog/cybersecurity-incidents-in-spain-2025-incibe-report/>

7 <https://www.schellman.com/blog/iso-certifications/what-are-iso-42001-requirements>

8 <https://www.incibe.es/en>

9 <https://kpmg.com/ch/en/insights/artificial-intelligence/iso-iec-42001.html>

10 <https://www.iso.org/obp/ui/en/>

11 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

12 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

13 <https://www.schellman.com/blog/iso-certifications/what-are-iso-42001-requirements>

14 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

15 https://www.linkedin.com/posts/tech-jacks-solutions_what-is-iso-42001-clause-9-performance-evaluation-activity-7426488503783395328-1e9U

16 <https://www.schellman.com/blog/iso-certifications/what-are-iso-42001-requirements>

17 <https://www.linkedin.com/learning/iso-iec-42001-2023-understanding-and-implementing-the-artificial-intelligence-management-system-aims-standard/ai-monitoring-management-and-analysis-evaluation-clause-9-1>

En los guías técnicas de implementación se explicita que la organización debe definir KPIs para el rendimiento del sistema de IA (precisión, sesgo, deriva, incidentes, tasas de intervención humana, reclamaciones) y para el propio AIMS (cumplimiento de políticas, tiempos de respuesta, madurez de controles). El mensaje subyacente es simple y cruel: si no puedes enseñar series temporales, umbrales, alertas y decisiones tomadas a partir de los datos, no estás cumpliendo el espíritu de ISO 42001 aunque tengas el sello en la pared.181920212223

2. Tipología de indicadores de ciberseguridad en ISO 42001

Aunque el texto oficial no enumera un catálogo normativo de métricas de seguridad, el ecosistema de guías 2025–2026 converge en una taxonomía bastante estable de indicadores de ciberseguridad específicos de IA. Estos indicadores se articulan sobre los controles de Anexo A en torno a gestión de riesgos, ciclo de vida de los sistemas de IA, datos, monitorización operacional, seguridad y abuso, y relación con terceros.242526272829303132333435

1) Indicadores de superficie de exposición y control básico

Se utilizan para responder a la pregunta “¿qué demonios estoy exponiendo?”. Entre los más habituales en las implementaciones 42001 de 2025–2026 aparecen:36373839404142

18 <https://secureprivacy.ai/blog/iso-42001-implementation-guide-2026>

19 <https://www.aigl.blog/iso-42001-checklist-of-implementation-steps/>

20 https://www.linkedin.com/posts/tech-jacks-solutions_what-is-iso-42001-clause-9-performance-evaluation-activity-7426488503783395328-1e9U

21 <https://www.schellman.com/blog/iso-certifications/what-are-iso-42001-requirements>

22 <https://www.linkedin.com/learning/iso-iec-42001-2023-understanding-and-implementing-the-artificial-intelligence-management-system-aims-standard/ai-monitoring-management-and-analysis-evaluation-clause-9-1>

23 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

24 <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>

25 <https://www.enz.ai/blog/iso-42001-practical-implementation-guide>

26 <https://www.isms.online/iso-42001/>

27 <https://www.scrut.io/post/ultimate-guide-to-iso-42001-2023>

28 <https://www.isms.online/iso-42001/annex-a-controls/>

29 <https://www.iso.org/obp/ui/en/>

30 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

31 <https://www.aigl.blog/iso-42001-checklist-of-implementation-steps/>

32 <https://www.schellman.com/blog/iso-certifications/what-are-iso-42001-requirements>

33 https://www.gsc-co.com/wp-content/uploads/2024/08/SCAN-ISO-420012023_-Web.pdf

34 <https://secureprivacy.ai/blog/iso-42001-implementation-guide-2026>

35 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

36 <https://www.enz.ai/blog/iso-42001-practical-implementation-guide>

37 <https://www.isms.online/iso-42001/annex-a-controls/>

38 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

39 <https://www.aigl.blog/iso-42001-checklist-of-implementation-steps/>

40 <https://www.schellman.com/blog/iso-certifications/what-are-iso-42001-requirements>

- Número de sistemas de IA en producción, por nivel de riesgo (alto/medio/bajo según EU AI Act u otro esquema).10141516
- Porcentaje de sistemas de IA con inventario y ficha técnica/model card completa, incluyendo dependencias externas, datos, versión del modelo y responsables.19151610
- Porcentaje de sistemas de IA con controles de autenticación, autorización y logging integrados con la infraestructura de seguridad corporativa (IAM, SIEM, SOAR, etc.).1718151610

2) Indicadores de riesgo y vulnerabilidad específicos de IA

El foco aquí es la “higiene” de seguridad y la exposición a ataques propios de modelos y datos. Son frecuentes:434445464748495051

- Número de vulnerabilidades o debilidades detectadas en sistemas de IA (clasificadas por criticidad) mediante pruebas de seguridad, red team de IA o auditorías.15161318105
- Porcentaje de modelos sometidos a pruebas de ataques de prompt injection, data poisoning, exfiltración de datos o “jailbreaks”, con tasas de éxito/fracaso de los ataques simulados.1613181015
- Tiempo medio de subsanación de vulnerabilidades de IA desde su detección hasta el cierre verificado (MTTR específico de IA).71310516

3) Indicadores de incidentes de seguridad en IA

Aquí la métrica estrella es la capacidad de detectar, contener y aprender de incidentes que involucran IA como objetivo, vector o amplificador del daño. Se suelen ver:52535455565758

41 <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>

42 <https://secureprivacy.ai/blog/iso-42001-implementation-guide-2026>

43 <https://www.scrut.io/post/ultimate-guide-to-iso-42001-2023>

44 <https://www.aigl.blog/iso-42001-checklist-of-implementation-steps/>

45 <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>

46 <https://www.enz.ai/blog/iso-42001-practical-implementation-guide>

47 <https://www.isms.online/iso-42001/>

48 <https://secureprivacy.ai/blog/iso-42001-implementation-guide-2026>

49 <https://www.isms.online/iso-42001/annex-a-controls/>

50 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

51 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

52 <https://www.aigl.blog/iso-42001-checklist-of-implementation-steps/>

53 <https://secureprivacy.ai/blog/iso-42001-implementation-guide-2026>

54 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

55 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

56 <https://www.schellman.com/blog/iso-certifications/what-are-iso-42001-requirements>

57 <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>

58 <https://www.enz.ai/blog/iso-42001-practical-implementation-guide>

- Número de incidentes de seguridad relacionados con IA (por tipo: fuga de datos, decisión indebida, uso malicioso, degradación de servicio ligada a modelo, etc.).131051516
- Porcentaje de incidentes de IA detectados automáticamente frente a incidentes detectados por usuarios, medios o terceros.105151613
- Tiempo medio de detección y contención de incidentes de IA (MTTD y MTTC).5715161310

4) Indicadores de monitorización continua: drift, anomalías y abuso

El AIMS exige “telemetría definida” y mecanismos de monitorización que cubran rendimiento, deriva, seguridad y feedback de usuarios, lo que se traduce en KPIs de vigilancia continua. Entre ellos:596061626364

- Porcentaje de modelos con detección de deriva (drift) activa y umbrales definidos, con número de alertas generadas y atendidas en un periodo.1914105
- Volumen de anomalías de predicción o uso (picos de consultas, patrones de abuso, inputs maliciosos) detectadas por los sistemas de IA y escaladas a los equipos de seguridad.151619105
- Porcentaje de sistemas de IA que incorporan mecanismos de rate limiting, filtrado de contenido y restricciones de contexto para minimizar vectores de abuso.1718161015

5) Indicadores de seguridad de datos para IA

La gestión de datos —especialmente datos personales, sensibles o críticos— aparece como uno de los ejes de controles en Annex A, con fuerte convergencia con ISO 27001 y el Reglamento de IA de la UE. Así, se utilizan métricas como:65666768

- Porcentaje de datasets de entrenamiento, validación y test con evaluación de sensibilidad, clasificación y controles de acceso documentados.16191015
- Porcentaje de datasets anonimizados o pseudonimizados cuando procede, con validación de efectividad de la anonimización.19101516
- Número de accesos no autorizados o intentos de acceso a datos de IA detectados y bloqueados.1817101516

59 https://www.linkedin.com/posts/tech-jacks-solutions_what-is-iso-42001-clause-9-performance-evaluation-activity-7426488503783395328-1e9U

60 <https://www.isms.online/iso-42001/annex-a-controls/>

61 <https://www.aigl.blog/iso-42001-checklist-of-implementation-steps/>

62 <https://www.schellman.com/blog/iso-certifications/what-are-iso-42001-requirements>

63 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

64 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

65 <https://www.iso.org/obp/ui/en/>

66 https://www.gsc-co.com/wp-content/uploads/2024/08/SCAN-ISO-420012023_-Web.pdf

67 <https://www.isms.online/iso-42001/annex-a-controls/>

68 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

6) Indicadores de cumplimiento, terceros y cadena de suministro de IA

Dado el uso masivo de servicios de IA de terceros, modelos fundacionales y APIs, el estándar refuerza el control sobre proveedores. De ahí que se midan:697071727374

- Porcentaje de proveedores de IA evaluados y aprobados según criterios de seguridad, privacidad y cumplimiento (incluyendo EU AI Act, RGPD y ENS).14101516
- Porcentaje de contratos con cláusulas específicas sobre seguridad de IA, disponibilidad, respuesta ante incidentes y derecho de auditoría.10151619
- Número de incidentes o incumplimientos de seguridad atribuibles a terceros de IA.151610

7) Indicadores de gobernanza, cultura y capacidad

Por último, un grupo de métricas “incómodas” para directivos porque midan algo peor que la latencia: la madurez organizativa en IA y ciberseguridad. Se ven ejemplos como:7576777879808182

- Porcentaje de casos de uso de IA sometidos a evaluación de impacto (técnica, ética y de seguridad) antes de pasar a producción.1416191015
- Porcentaje de personal crítico (desarrolladores de IA, MLOps, ciberseguridad) que recibe formación específica anual en riesgos de IA, seguridad de modelos y normativas aplicables.813161015
- Número de revisiones de la alta dirección del AIMS al año y decisiones tomadas en base a indicadores (ajustes de recursos, rediseño de controles, cambios de apetito de riesgo).57

69 https://www.gsc-co.com/wp-content/uploads/2024/08/SCAN-ISO-420012023_-Web.pdf

70 <https://www.iso.org/obp/ui/en/>

71 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

72 <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>

73 <https://www.enz.ai/blog/iso-42001-practical-implementation-guide>

74 <https://www.isms.online/iso-42001/annex-a-controls/>

75 <https://www.schellman.com/blog/iso-certifications/what-are-iso-42001-requirements>

76 <https://secureprivacy.ai/blog/iso-42001-implementation-guide-2026>

77 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

78 <https://www.aigl.blog/iso-42001-checklist-of-implementation-steps/>

79 <https://www.enz.ai/blog/iso-42001-practical-implementation-guide>

80 <https://www.isms.online/iso-42001/annex-a-controls/>

81 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

82 <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>

3. Tendencias desde 2025: de KPIs “ISO 27001 con pegatinas de IA” a métricas realmente específicas

En 2023–2024 abundaban las implementaciones que básicamente reciclaban KPIs de ISO 27001 con un ligero maquillaje semántico de “modelo” y “dataset”. A partir de 2025, sin embargo, el conjunto de experiencias acumuladas, el empuje del EU AI Act y la presión de auditores y grandes consultoras ha desplazado la curva hacia métricas diseñadas explícitamente para

Una primera tendencia clara es la integración de métricas de seguridad y métricas de calidad de modelos en paneles unificados, de manera que desviaciones de precisión, sesgo o drift se traten como indicadores de riesgo operativo y de ciberseguridad, no como “problemas de ciencia de datos”. Se está normalizando, por ejemplo, definir umbrales de deriva o de “toxicidad” de respuestas que disparan procesos de gestión de incidentes y no solo tareas de retraining.

La segunda tendencia es la formalización de telemetría de IA: logging detallado de prompts, contexto, salidas, decisiones automáticas, overrides humanos, señales de abuso y correlación con eventos de seguridad tradicionales. Esto permite indicadores como “porcentaje de respuestas bloqueadas por filtros de contenido”, “número de intentos de exfiltración de datos vía modelo” o “tasa de overrides humanos por tipo de decisión y unidad de negocio”.

83 <https://www.schellman.com/blog/ai-services/ai-governance-and-iso-42001-faqs>

84 <https://kpmg.com/ch/en/insights/artificial-intelligence/iso-iec-42001.html>

85 <https://secureprivacy.ai/blog/iso-42001-implementation-guide-2026>

86 <https://www.scrut.io/post/ultimate-guide-to-iso-42001-2023>

87 <https://www.schellman.com/blog/iso-certifications/what-are-iso-42001-requirements>

88 <https://www.enz.ai/blog/iso-42001-practical-implementation-guide>

89 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

90 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

91 <https://www.aigl.blog/iso-42001-checklist-of-implementation-steps/>

92 <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>

93 <https://secureprivacy.ai/blog/iso-42001-implementation-guide-2026>

94 <https://www.enz.ai/blog/iso-42001-practical-implementation-guide>

95 <https://www.isms.online/iso-42001/annex-a-controls/>

96 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

97 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

98 <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>

99 https://www.linkedin.com/posts/tech-jacks-solutions_what-is-iso-42001-clause-9-performance-evaluation-activity-7426488503783395328-1e9U

100 <https://www.enz.ai/blog/iso-42001-practical-implementation-guide>

En tercer lugar, se aprecia una convergencia entre los requisitos de monitorización poscomercialización del EU AI Act y los KPIs de ISO 42001, de forma que los mismos indicadores y registros sirvan para demostrar cumplimiento ante reguladores y auditores de certificación. Guías industriales comparan explícitamente Annex A de ISO 42001 con Annex IV del AI Act y sugieren métricas que cubren a la vez logs, gestión de riesgos, pruebas y supervisión humana.107108109110111112113114

Por último, el incremento de incidentes y ataques que usan IA como vector o amplificador ha empujado a medir, con cierto dramatismo, la parte de los SOC y CERT dedicada a IA: número de runbooks específicos, porcentaje de analistas formados en amenazas de IA, incidentes de phishing o malware asistidos por IA y uso de IA defensiva. Esta “IA que se defiende de la IA” también empieza a generar sus propios indicadores de desempeño y seguridad, creando una recursividad que haría feliz a cualquier filósofo de la ciencia y muy infeliz al equipo de reporting.115116117118119120121

4. Aplicación territorial a España: de ISO 42001 a un cuadro de mando nacional

España llega a ISO 42001 con cierta ventaja: una Estrategia Nacional de IA, una Agenda España Digital 2025, un Esquema Nacional de Seguridad maduro y un ecosistema de INCIBE, CCN-CERT y otros actores acostumbrados a reportar indicadores a escala país. En 2024 se registraron más de

101 <https://secureprivacy.ai/blog/iso-42001-implementation-guide-2026>

102 <https://www.isms.online/iso-42001/annex-a-controls/>

103 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

104 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

105 <https://www.aigl.blog/iso-42001-checklist-of-implementation-steps/>

106 <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>

107 <https://kpmg.com/ch/en/insights/artificial-intelligence/iso-iec-42001.html>

108 <https://www.schellman.com/blog/ai-services/ai-governance-and-iso-42001-faqs>

109 <https://www.scrut.io/post/ultimate-guide-to-iso-42001-2023>

110 <https://www.schellman.com/blog/iso-certifications/what-are-iso-42001-requirements>

111 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

112 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

113 <https://www.aigl.blog/iso-42001-checklist-of-implementation-steps/>

114 <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>

115 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

116 <https://eiposgrados.com/eng/cybersecurity-blog/cybersecurity-incidents-in-spain-2025-incibe-report/>

117 <https://www.incibe.es/en>

118 <https://www.scrut.io/post/ultimate-guide-to-iso-42001-2023>

119 <https://secureprivacy.ai/blog/iso-42001-implementation-guide-2026>

120 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

121 <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>

100.000 ciberataques en España, con un incidente “muy grave” aproximadamente cada tres días, y en 2025 INCIBE gestionó más de 122.000 incidentes, casi la mitad de ellos vinculados a malware con fuerte presencia de ransomware.¹²²¹²³¹²⁴¹²⁵¹²⁶

Si superponemos el marco de ISO 42001 sobre esta realidad, el resultado natural es un sistema de indicadores de ciberseguridad de IA que se integre con la estadística ya consolidada, pero añadiendo dimensiones específicas de IA. A nivel nacional podrían definirse, entre otros, indicadores como:

- Porcentaje de organismos del sector público estatal y comunidades autónomas que aplican ISO 42001 (o marco equivalente) a sus sistemas de IA críticos, alineados con el ENS y el AI Act.¹²⁴⁹
- Número de incidentes de ciberseguridad en España en los que un sistema de IA es vector, objetivo o amplificador del ataque, con desglose por sector crítico (banca, transporte, energía) y tipo de amenaza.⁶³⁸
- Porcentaje de sistemas de IA utilizados en servicios públicos esenciales que disponen de evaluación de impacto, telemetría de seguridad y procesos de revisión periódica conforme a los principios de ISO 42001.²⁴⁹¹¹⁵

La propia Estrategia Nacional de IA hace hincapié en capacidades de supercomputación, laboratorios de computación cuántica y refuerzo de la ciberseguridad coordinada por INCIBE, lo que sugiere indicadores de infraestructuras críticas de IA: disponibilidad, incidentes, capacidad de respuesta y resiliencia. En la práctica, esto puede traducirse en cuadros de mando que combinen métricas de capacidad (nodos de cómputo, servicios de IA en operación), de riesgo (evaluaciones realizadas, niveles de riesgo residual) y de desempeño de seguridad (incidentes, tiempos de respuesta, efectividad de controles).¹²⁷¹²⁸¹²⁹¹³⁰¹³¹¹³²¹³³

A nivel empresarial, los sectores más atacados en España —banca, transporte, energía— son, paradójicamente, los más proclives a desplegar IA avanzada para detección de fraude, predicción de fallos o gestión de demanda, por lo que son candidatos naturales a proyectos piloto de ISO 42001 con fuertes métricas de ciberseguridad. Nada impide (y mucho anima) que INCIBE y ENISA

122 https://portal.mineco.gob.es/RecursosArticulo/mineco/ministerio/ficheros/210204_Digital_Spain_2025.pdf

123 <https://eiposgrados.com/eng/cybersecurity-blog/cybersecurity-incidents-in-spain-2025-incibe-report/>

124 https://ai-watch.ec.europa.eu/countries/spain/spain-ai-strategy-report_en

125 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

126 <https://www.incibe.es/en>

127 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

128 <https://eiposgrados.com/eng/cybersecurity-blog/cybersecurity-incidents-in-spain-2025-incibe-report/>

129 <https://www.incibe.es/en>

130 <https://kpmg.com/ch/en/insights/artificial-intelligence/iso-iec-42001.html>

131 https://ai-watch.ec.europa.eu/countries/spain/spain-ai-strategy-report_en

132 https://portal.mineco.gob.es/RecursosArticulo/mineco/ministerio/ficheros/210204_Digital_Spain_2025.pdf

133 <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>

publiquen, además de estadísticas de incidentes, indicadores agregados sobre el grado de adopción de prácticas de gobernanza de IA tipo ISO 42001 y el impacto observado en la reducción o contención de incidentes.134135136137138

5. Comparación internacional y líneas propositivas

A escala global, ISO 42001 se está convirtiendo en la lengua franca con la que se discuten KPIs de ciberseguridad en IA, de forma análoga a lo que ISO 27001 hizo para la seguridad de la información. Países con fuertes marcos regulatorios de IA (UE con el AI Act, Reino Unido con su enfoque de “pro-innovación”, y jurisdicciones asiáticas que combinan estrategia industrial con controles de seguridad) están convergiendo en una combinación de indicadores de gestión del riesgo, incidentes, telemetría, proveedores y cultura organizativa.139140141142143144145146147

La posición de España, con un ecosistema de ciberseguridad consolidado y una estrategia digital que explícitamente cita IA y ciberseguridad como ejes, permite aspirar a algo más que simplemente adoptar ISO 42001: puede usarlo para definir un “cuadro de mando nacional de IA segura y confiable”. Eso implica, entre otras cosas, armonizar indicadores sectoriales, incorporar requisitos de reporting de IA en esquemas de licencias y supervisión, y fomentar que los datos agregados se utilicen para investigación académica y mejora del propio sistema de gestión.148149150151152153

Desde una perspectiva más filosófica (y ligeramente irónica), ISO 42001 nos invita a abandonar la ilusión de que basta con “confiar en la IA” o “confiar en el proveedor” y a aceptar que la confianza se

134 <https://eiposgrados.com/eng/cybersecurity-blog/cybersecurity-incidents-in-spain-2025-incibe-report/>

135 <https://www.incibe.es/en>

136 https://ai-watch.ec.europa.eu/countries/spain/spain-ai-strategy-report_en

137 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

138 <https://www.scrut.io/post/ultimate-guide-to-iso-42001-2023>

139 <https://ecohumanism.co.uk/joe/ecohumanism/article/view/6985>

140 <https://www.schellman.com/blog/ai-services/ai-governance-and-iso-42001-faqs>

141 <https://www.iso.org/obp/ui/en/>

142 <https://kpmg.com/ch/en/insights/artificial-intelligence/iso-iec-42001.html>

143 <https://www.scrut.io/post/ultimate-guide-to-iso-42001-2023>

144 <https://www.schellman.com/blog/iso-certifications/what-are-iso-42001-requirements>

145 <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

146 <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

147 <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>

148 <https://ecohumanism.co.uk/joe/ecohumanism/article/view/6985>

149 <https://www.incibe.es/en>

150 https://ai-watch.ec.europa.eu/countries/spain/spain-ai-strategy-report_en

151 https://portal.mineco.gob.es/RecursosArticulo/mineco/ministerio/ficheros/210204_Digital_Spain_2025.pdf

152 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

153 <https://eiposgrados.com/eng/cybersecurity-blog/cybersecurity-incidents-in-spain-2025-incibe-report/>

mide, se audita y se corrige igual que cualquier otra propiedad de un sistema complejo. El reto, a nivel nacional e internacional, no es sólo definir indicadores brillantes en papel, sino construir incentivos para que se reporten con honestidad y se usen para tomar decisiones incómodas: detener despliegues, cambiar proveedores, rediseñar arquitecturas o incluso admitir que ciertos usos de IA sencillamente no son aceptables.¹⁵⁴¹⁵⁵¹⁵⁶¹⁵⁷¹⁵⁸¹⁵⁹¹⁶⁰¹⁶¹¹⁶²¹⁶³

¹⁵⁴ <https://www.schellman.com/blog/ai-services/ai-governance-and-iso-42001-faqs>

¹⁵⁵ <https://www.iso.org/obp/ui/en/>

¹⁵⁶ <https://kpmg.com/ch/en/insights/artificial-intelligence/iso-iec-42001.html>

¹⁵⁷ <https://ecohumanism.co.uk/joe/ecohumanism/article/view/6985>

¹⁵⁸ <https://www.scrut.io/post/ultimate-guide-to-iso-42001-2023>

¹⁵⁹ <https://www.schellman.com/blog/iso-certifications/what-are-iso-42001-requirements>

¹⁶⁰ <https://www.isms.online/iso-42001/annex-a-controls/>

¹⁶¹ <https://www.surecloud.com/resource-hub/iso-42001-annex-a-controls>

¹⁶² <https://techjacksolutions.com/iso/42001/what-is-iso-42001-clause-9/>

¹⁶³ <https://cloudsecurityalliance.org/blog/2025/05/08/iso-42001-lessons-learned-from-auditing-and-implementing-the-framework>